

Plantilla: Análisis de Riesgos y Modelado de Amenazas

ANÁLISIS DE RIESGOS - [NOMBRE DEL PROYECTO]	
Documento de Threat Modeling	
1. INFORMACIÓN GENERAL DEL PROYECTO	
Fecha de inicio:	[DD/MM/AAAA]
Fecha de entrega:	[DD/MM/AAAA]
Versión del documento:	[1.0]
Equipo de análisis:	[Nombres de los integrantes del grupo]
1.1 Descripción del Sistema	
[Breve descripción del sistema/proyecto a analizar]	
1.2 Alcance del Análisis	
Componentes incluidos:	
- [Componente 1]	
- [Componente 2]	
- [Componente 3]	
Componentes fuera de alcance:	
- [Componente excluido]	
- [Razón de exclusión]	
1.3 Supuestos	
- [Supuesto 1]	
- [Supuesto 2]	

2. IDENTIFICACIÓN DE ACTIVOS					
2.1 Activos de Información					
Propietario	ID	Activo	Tipo	Dato	Clasificación
	A01	[Nombre del activo]	[PII/Financiero]	[Alta/Media]	
	[Usuario/Sis]		/Salud/etc]		
	A02				
	...				
2.2 Activos Tecnológicos					
	ID	Activo	Tipo	Criticidad	Notas
	T01	[Servidor/APP]	[Hardware/	[Alta]	[Descripción]
			Software]		
	...				
2.3 Activos Intangibles					
- Reputación de la empresa - Confianza de clientes - Propiedad intelectual					
3. ARQUITECTURA DEL SISTEMA					
3.1 Diagrama de Arquitectura					

[Insertar diagrama aquí o describir componentes]														
3.2 Flujo de Datos														
Usuario → [Frontend] → [API Gateway] → [Backend] → [Base de Datos] ↓ [Servicios Externos]														
3.3 Actores del Sistema														
<table><tr><th>Actor</th><th>Descripción</th><th>Privilegios</th></tr><tr><td>Usuario final</td><td>Cliente que usa la aplicación</td><td>[Limitados]</td></tr><tr><td>Administrador</td><td>Gestor del sistema</td><td>[Completo]</td></tr><tr><td>Atacante</td><td>Actor malicioso externo</td><td>[Ninguno - evaluar]</td></tr></table>			Actor	Descripción	Privilegios	Usuario final	Cliente que usa la aplicación	[Limitados]	Administrador	Gestor del sistema	[Completo]	Atacante	Actor malicioso externo	[Ninguno - evaluar]
Actor	Descripción	Privilegios												
Usuario final	Cliente que usa la aplicación	[Limitados]												
Administrador	Gestor del sistema	[Completo]												
Atacante	Actor malicioso externo	[Ninguno - evaluar]												
3.4 Trust Boundaries														
[Identificar límites de confianza en el diagrama]														
4. ANÁLISIS DE AMENAZAS - METODOLOGÍA STRIDE														
4.1 Aplicación de STRIDE														
CATEGORÍAS STRIDE														
S - Spoofing	Suplantación de identidad													

5.1 Criterios DREAD

Criterio	Descripción	Peso
Damage	Daño potencial si se explota	1.0
Reproducibility	Facilidad de reproducción	1.0
Exploitability	Dificultad para explotar	1.0
Affected Users	Cantidad de usuarios afectados	1.0
Discoverability	Facilidad de descubrimiento	1.0

Escala: 1-10 (1=mínimo, 10=máximo)

5.2 Matriz de Riesgos

	ID	Amenaza	D	R	E	A	D	TOTAL
Nivel								
	TH01	[Descripción]	8	7	6	9	7	37/50
ALTO	TH02							
	...							

5.3 Escala de Severidad

- CRÍTICO (40-50): Remediar inmediatamente
- ALTO (30-39): Remediar ASAP
- MEDIO (20-29): Remediar en siguiente sprint
- BAJO (10-19): Monitorear
- MÍNIMO (1-9): Aceptar riesgo

6. MAPA DE ATAQUE (ATT&CK)

6.1 Técnicas Identificadas

	ID	Técnica	Tactic	Mitigación
	T1078	Valid Accounts	Initial Access	MFA, IAM
	T1190	Exploit Public-Facing App	Initial Access	WAF,
Patching	T1486	Data Encrypted for Impact	Impact	Backups,
Encryption				

6.2 Visualización

[Insertar diagrama de MITRE ATT&CK Navigator o descripción]

7. PLAN DE MITIGACIÓN

7.1 Controles de Seguridad

	ID	Amenaza	Control de Seguridad	Prioridad
Estado				
	C01	TH01	[Control a implementar]	[1]
[Pend]	C02	TH02		

7.2 Controles por Categoría

- CONTROLES PREVENTIVOS:
- [] Autenticación multifactor
 - [] Cifrado de datos en tránsito y en reposo
 - [] Validación de entrada
 - [] Principio de mínimo privilegio
 - [] Segmentación de red
- CONTROLES DETECTIVOS:
- [] Logging de eventos de seguridad
 - [] Monitorización con SIEM
 - [] Alertas de anomalías
 - [] Revisión de logs periódica

CONTROLES CORRECTIVOS:

- [] Plan de respuesta a incidentes
- [] Procedimientos de backup
- [] Plan de recuperación

8. MATRIZ DE CONTROLES (NIST/ISO 27001)

Referencia	ID	Control	Descripción	
NIST AC-1	AC-1	Access Control	Política de control de acceso	
NIST AU-2	AU-2	Audit Events	Eventos de auditoría	
NIST SC-8	SC-8	Transmission Conf.	Confidencialidad en tránsito	NIST
	...			

9. RIESGOS RESIDUALES

Justificación/Aceptación	ID	Riesgo Residual	Prob.	Imp.	
	R01	[Riesgo que queda]	[M]	[L]	[Por qué se acepta]

10. CONCLUSIONES Y RECOMENDACIONES

10.1 Resumen Ejecutivo

[Resumen de hallazgos principales]

10.2 Recomendaciones Prioritarias

1. [Recomendación más importante]
2. [Segunda recomendación]
3. [Tercera recomendación]

10.3 Próximos Pasos

- [] Implementar controles de alta prioridad
- [] Re-evaluar en [X] meses
- [] Continuous monitoring

ANEXOS

A1. Glosario

- STRIDE: Spoofing, Tampering, Repudiation, Information Disclosure, DoS, EoP
- DREAD: Damage, Reproducibility, Exploitability, Affected Users, Discoverability
- CWE: Common Weakness Enumeration
- CVE: Common Vulnerabilities and Exposures
- SIEM: Security Information and Event Management

A2. Referencias

- NIST SP 800-30: Guide for Conducting Risk Assessments
- ISO/IEC 27001: Information Security Management
- MITRE ATT&CK Framework
- OWASP Top 10 2021

A3. Herramientas Utilizadas

- [Herramienta 1]: [Propósito]
- [Herramienta 2]: [Propósito]

Versión: 1.0
Fecha: [DD/MM/AAAA]
Equipo: [Nombres]

Checklist de Entregables

Entregable	Descripción	Estado
☐	Documento completo con todas las secciones	
☐	Diagrama de arquitectura con trust boundaries	
☐	Inventario de activos (información y tecnológico)	
☐	Matriz STRIDE completa	
☐	Análisis DREAD de amenazas prioritarias	
☐	Mapa de técnicas ATT&CK	
☐	Plan de mitigación priorizado	
☐	Controles documentados (NIST/ISO)	
☐	Riesgos residuales identificados	
☐	Conclusiones y recomendaciones	

Escala DREAD Detallada

Puntuación	Daño (D)	Reproducibilidad (R)	Explotabilidad (E)	Afectados (A)	Descubribilidad (D)
10	Completo sistema	Siempre	Fácil	Todos	Muy fácil

Puntuación	Daño (D)	Reproducibilidad (R)	Explotabilidad (E)	Afectados (A)	Descubribilidad (D)
7-9	Significativo	Frecuente	Moderado	Muchos	Fácil
4-6	Moderado	A veces	Difícil	Algunos	Promedio
1-3	Mínimo	Rara vez	Muy difícil	Pocos	Difícil